PART 2 · INFOGRAPHIC SUMMARY

Mal — Endpoint-to-Identity Security Architecture

Vishnudev Ammuppilly · November 2026 · Companion to Part 1 (mal-jml)

~50 staff → 200 | macOS-majority fleet | Google Workspace | Regulated fintech · customer financial data

CORE PRINCIPLE

Okta is the only door.

Every app signs in through Okta with local passwords switched off. One policy engine decides access; one lifecycle event revokes it. Device health is an **input** to that decision — never a side gate users can route around.

01 How the stack fits together

Three trust boundaries. Each one hands a signal to the next.

TB1 · DEVICE

Is the laptop trusted?

Jamf Pro — is it managed? FileVault, OS floor, no admin, USB/AirDrop limits

CrowdStrike Falcon — is it healthy right now? EDR + posture score

Okta Verify FastPass — phishing-resistant sign-in

→

TB2 · IDENTITY

Okta decides

Combines **who** the user is + **device signals** + **how sensitive** the app is.

Runs joiner / mover / leaver and pushes accounts to apps via **SCIM**.

→

TB3 · APPS & SECRETS

Apps follow Okta

Google Workspace, Slack, AWS, GitHub — SSO only

1Password — SSO unlock for staff; admins keep Secret Key + password

SIEM — alerts & evidence

Why CrowdStrike Falcon for EDR?

Defender's big edge is bundling with Microsoft 365 — Mal runs Google Workspace + Okta, so that edge disappears. Falcon has the stronger macOS sensor and feeds its posture score straight into Okta. Check Point has the weakest identity integration.

Trade-off: cost is material at 50 seats.

The admin plane is locked down

- Separate admin identities
- FIDO2 keys only, managed device required
- No standing super-admin
- Break-glass accounts sealed in 1Password, alert on use

1Password trade-off

"Unlock with SSO" is easier for staff but makes 1Password depend on Okta. **Decision:** SSO unlock for staff; owners/admins keep the independent Secret Key + password.

02 Who gets in, from where

Jamf answers **"is this device managed?"**, Falcon answers **"is it healthy right now?"**, and Okta combines both with the user and the app's sensitivity. Worked example — one engineer, **Aisha**:

Her device	Gmail / Slack	1Password	AWS production
Company MacBook Jamf-managed, Falcon healthy	✓ ALLOW with FastPass	✓ ALLOW with FastPass	◖ LIMITED Engineering role only, FIDO2 every sign-in, 1-hour sessions, just-in-time elevation
Internet café PC unmanaged	✕ BLOCK Browser-only access needs GWS Enterprise — check licence first	✕ BLOCK A keylogger would expose every secret	✕ BLOCK

Device trust gets you through the door — the most sensitive systems check again.

Two known gaps — and how they're handled

Gap 1 · Device health is checked only at sign-in

If Falcon detects malware 10 minutes after Aisha signs in, her session stays valid until it expires.

High/critical Falcon alert → Contain host → Clear Okta sessions → Slack alert → Next sign-in denied

Day one: the playbook above, reusing Part 1's Okta and Slack code. Medium alerts go to an analyst to avoid false-positive lockouts.
Later: continuous signal sharing (Okta Identity Threat Protection — paid add-on).

Gap 2 · App sessions outlive the Okta session

Clearing Okta does not end a session AWS has already issued. **Fix:** keep AWS session duration short, and include "revoke active AWS role sessions" in incident response.

✓ ALLOW full access ◖ LIMITED extra checks ✕ BLOCK no access

03 Stopping data leaks & email spoofing

The real risk at 50 people

Not a mastermind insider — it's customer data sent to **personal Gmail**, a **public Drive link**, an **over-scoped OAuth app**, or a **secret pasted into Slack**. Day one targets those paths with cheap, low-noise controls. Expensive content inspection comes later.

Channel	Day one (50 people)	Defer (100–200 people)
Email	Block auto-forward to outside domains. Warn → quarantine card numbers, IBANs, Emirates IDs sent externally. TLS to partners.	Gmail DLP with custom detectors (Enterprise tier); extra attachment sandboxing
Drive / SaaS	Share only with allowlisted partner domains. No "anyone with link" on customer data. OAuth app allowlist.	Auto-labelling; CASB for shadow SaaS; Slack DLP
Endpoint	FileVault, no local admin, USB read-only, AirDrop limited. GitHub secret scanning.	Full endpoint content DLP — noisiest & costliest
Policy	One-page, 3-tier classification: Public / Internal / Confidential-Customer. Rules target the top tier only.	Labels enforced in tooling

Email authentication: ramp up, don't jump

SPF / DKIM / DMARC stop outsiders **pretending to be Mal** (fake payment instructions, fake support). They do **not** stop staff leaking data — that's DLP's job. Enforcing too early silently drops real mail like invoices and HR emails.

STEP 1 · DAY ONE

p=none · watch

List every sender. DKIM 2048-bit. SPF under 10 lookups. Reports to a processor. MTA-STS on.

Parked domains → reject immediately.

STEP 2 · WEEKS 2–6

p=quarantine · ramp

Fix alignment from reports, raise pct to 100. Move marketing mail to subdomains to isolate vendor compromise.

STEP 3 · END STATE

p=reject · everywhere

Every domain and subdomain enforced. DMARC is the enforcement point.

Deferred: BIMI, lookalike-domain monitoring (~100 staff).

SPF: ~all or -all?

~all on sending domains (DMARC enforces, avoids breaking forwarded mail). **-all** on domains that never send.

04 Part 1 build — honest scorecard

✓ Run live · 31 Oct 2026

Okta — create user, add to group, clear sessions, suspend/deactivate
Slack — real webhook alert
Screenshots + Okta System Log in README

○ Mocked · same HTTP client

Google Workspace (needs owned domain) · **1Password** (needs SCIM server) · **Jamf** (no free tenant)
33 tests at HTTP level

FOUND & FIXED

Template values looked real

Blanked them; startup check + test added.

FOUND & FIXED

Token sent to wrong tenant

Fixed URL, rotated token. 401 handled correctly.

FOUND & FIXED

Alert said "suspend", Okta deactivated

Now reports the real outcome.

Known issues, not fixed

- A rerun escalates (suspend → deactivate)
- No confirmation before a live leaver
- Mocks too forgiving — can't catch "wrong user"

Biggest change for production

HR system → Okta → SCIM to every app. The script shrinks to what Okta can't do: token revocation, Jamf, alerts, evidence. Plus scoped OAuth, no long-lived keys, queue with retries, logs to SIEM.

Deviation from brief: used 1Password SCIM, not Connect/Events API — neither can change vault access; SCIM controls group membership.

05 ISO 27001:2022 mapping

A.5.18 Access rights

Covered: one leaver run removes access everywhere and writes an audit record. Joiners get access by group.

Evidence, strongest first: Okta System Log → run audit record → Slack alert (notice only)

Gaps: no link to who approved; no HR termination time; no periodic access reviews; editable local log.

A.5.16 Identity management

Covered: one identity across Okta, GWS, 1Password. Joiner reruns don't duplicate. Leavers suspended, not deleted.

Gaps: no orphan-account reconciliation; service accounts have no owner or review; no deletion point after suspension.

CBUAE note: if Mal holds a CBUAE licence, the same evidence supports its access-control expectations — to be checked against the licence category.